

Индивидуальный проект

2 Этап

Панина Жанна Валерьевна

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	16
	Список литературы	17

Список иллюстраций

4.1	Клонирование репозитория	9
4.2	Перемещение по директориям	9
4.3	Редактирование файла в nano	10
4.4	Запуск mysql	10
4.5	Авторизация в базе данных и предоставление привилегий	11
4.6	Перемещение между директориями	11
4.7	Редактирование файла	12
4.8	Запуск службы	12
4.9	Запуск веб-приложения	13
4.10	«Создание базы данных»	13
4.11	Авторизация	14
4.12	Домашняя страница DVWA	15

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA

2 Задание

Установить дистрибутив DVWA в Kali Linux

3 Теоретическое введение

DVWA - это уязвимое веб-приложение, разработанное на PHP и MYSQL.

Некоторые из уязвимостей веб приложений, который содержит DVWA: - Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей. - Исполнение (внедрение) команд: Выполнение команд уровня операционной системы. - Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений. - Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение. - SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение. - Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер. - Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS. - Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA: - Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом. - Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. - Средний — этот уровень безопасности

предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу. - Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб-приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации. **[guide]**

4 Выполнение лабораторной работы

Перехожу в директорию `/var/www/html`. Затем клонирую нужный репозиторий GitHub (?@fig-001).

```
(zspanina@kali)-[~]
$ cd /var/www/html/

(zspanina@kali)-[/var/www/html]
$ git clone https://github.com/digininja/DVWA.git
fatal: could not create work tree dir 'DVWA': Permission denied

(zspanina@kali)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA.git
[sudo] password for zspanina:
Cloning into 'DVWA' ...
remote: Enumerating objects: 5676, done.
remote: Counting objects: 100% (25/25), done.
remote: Compressing objects: 100% (13/13), done.
remote: Total 5676 (delta 19), reused 12 (delta 12), pack-reused 5651 (from 2)
Receiving objects: 100% (5676/5676), 2.71 MiB | 5.34 MiB/s, done.
Resolving deltas: 100% (2834/2834), done.
```

Рисунок 4.1: Клонирование репозитория

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога (?@fig-002).

```
(zspanina@kali)-[/var/www/html]
$ cd DVWA/

(zspanina@kali)-[/var/www/html/DVWA]
$ ls
about.php  Dockerfile  index.php  README.ar.md  README.ko.md  README.uk.md  security.txt
CHANGELOG.md  docs  instructions.php  README.es.md  README.md  README.vi.md  setup.php
compose.yml  dvwa  login.php  README.fa.md  README.pl.md  README.zh.md  tests
COPYING.txt  external  logout.php  README.fr.md  README.pt.md  robots.txt  vulnerabilities
database  hackable  phpinfo.php  README.id.md  README.ru.md  SECURITY.md
php.ini  README.it.md  README.tr.md  security.php

(zspanina@kali)-[/var/www/html/DVWA]
$ cd config/

(zspanina@kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist

(zspanina@kali)-[/var/www/html/DVWA/config]
$ sudo mv config.inc.php.dist config.inc.php

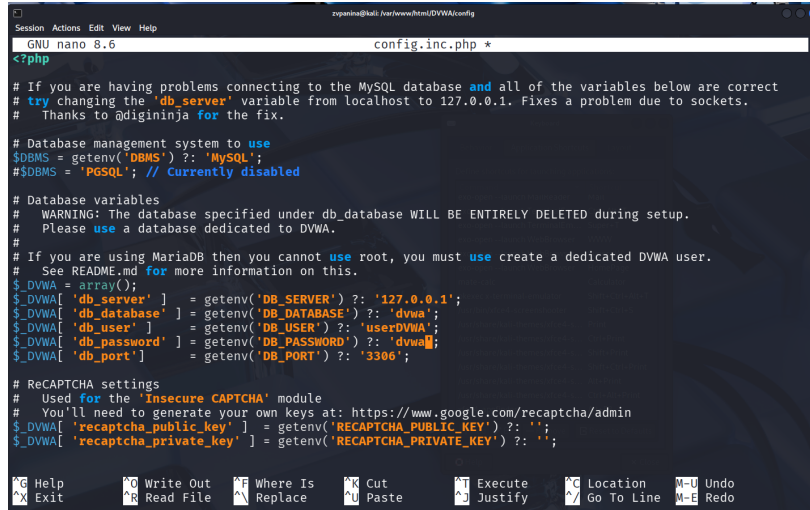
(zspanina@kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php
```

Рисунок 4.2: Перемещение по директориям

Изменяю файл, используемый для настройки DVWA `config.inc.php.dist`

на `config.inc.php`.

Далее открываю файл в текстовом редакторе `папо` (?@fig-003). Изменяю данные об имени пользователя и пароле.



```
GNU nano 8.6 config.inc.php *
<?php
# If you are having problems connecting to the MySQL database and all of the variables below are correct
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to sockets.
# Thanks to @digininja for the fix.

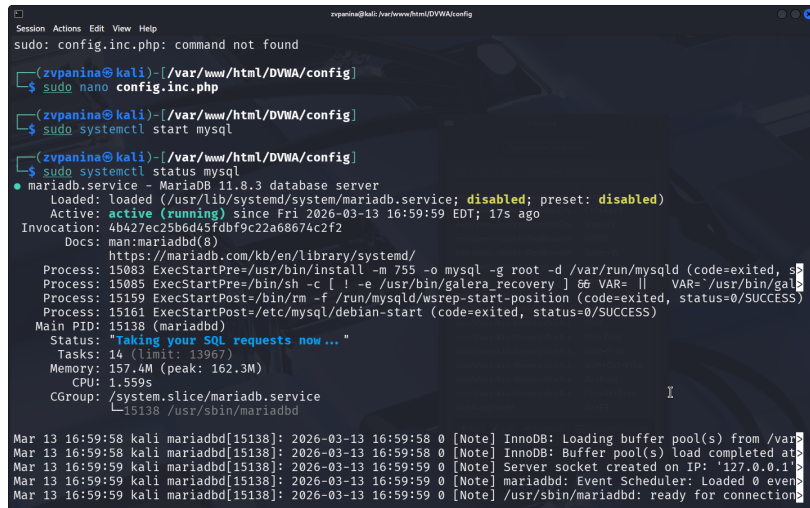
# Database management system to use
$DBMS = getenv('DBMS') ? 'MySQL' : 'MySQL';
# $DBMS = 'PGSQL'; // Currently disabled

# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$DVWA = array();
$DVWA['db_server'] = getenv('DB_SERVER') ? '127.0.0.1';
$DVWA['db_database'] = getenv('DB_DATABASE') ? 'dvwa';
$DVWA['db_user'] = getenv('DB_USER') ? 'userDVWA';
$DVWA['db_password'] = getenv('DB_PASSWORD') ? 'dvwa';
$DVWA['db_port'] = getenv('DB_PORT') ? '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptcha/admin
$DVWA['recaptcha_public_key'] = getenv('RECAPTCHA_PUBLIC_KEY') ? '';
$DVWA['recaptcha_private_key'] = getenv('RECAPTCHA_PRIVATE_KEY') ? '';
```

Рисунок 4.3: Редактирование файла в `папо`

По умолчанию в Kali Linux установлен `mysql`, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (?@fig-004).

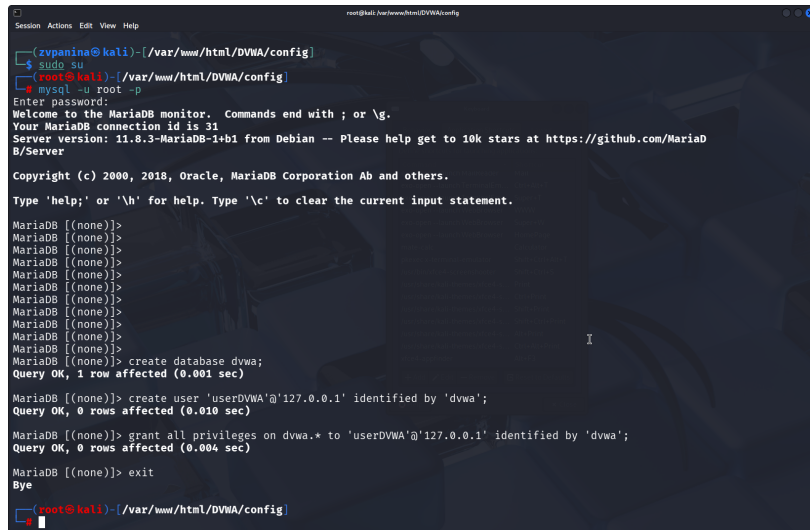


```
sudo: config.inc.php: command not found
(zvpanina@kali) [/var/www/html/DVWA/config]
$ sudo nano config.inc.php
(zvpanina@kali) [/var/www/html/DVWA/config]
$ sudo systemctl start mysql
(zvpanina@kali) [/var/www/html/DVWA/config]
$ sudo systemctl status mysql
● mariadb.service - MariaDB 11.8.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-03-13 16:59:59 EDT; 17s ago
     Invocation: 4b427ec25b6d45fdbf9c22a68674c2f2
       Docs: man:mariadbd(8)
            https://mariadb.com/kb/en/library/systemd/
   Process: 15083 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d /var/run/mysqld (code=exited, s
   Process: 15085 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ] && VAR= || VAR=/usr/bin/gal
   Process: 15159 ExecStartPost=/bin/rm -f /run/mysqld/wsrep-start-position (code=exited, status=0/SUCCESS)
   Process: 15161 ExecStartPost=/etc/mysql/debian-start (code=exited, status=0/SUCCESS)
  Main PID: 15138 (mariadbd)
    Status: "Taking your SQL requests now..."
     Tasks: 14 (limit: 13967)
    Memory: 157.4M (peak: 162.3M)
       CPU: 1.559s
    CGroup: /system.slice/mariadb.service
           └─15138 /usr/sbin/mariadbd

Mar 13 16:59:58 kali mariadbd[15138]: 2026-03-13 16:59:58 0 [Note] InnoDB: Loading buffer pool(s) from /var
Mar 13 16:59:58 kali mariadbd[15138]: 2026-03-13 16:59:58 0 [Note] InnoDB: Buffer pool(s) load completed at
Mar 13 16:59:59 kali mariadbd[15138]: 2026-03-13 16:59:59 0 [Note] Server socket created on IP: '127.0.0.1'
Mar 13 16:59:59 kali mariadbd[15138]: 2026-03-13 16:59:59 0 [Note] mariadbd: Event Scheduler: Loaded 0 even
Mar 13 16:59:59 kali mariadbd[15138]: 2026-03-13 16:59:59 0 [Note] /usr/sbin/mariadbd: ready for connection
```

Рисунок 4.4: Запуск `mysql`

Авторизируюсь в базе данных от имени пользователя root (?@fig-005). Появляется командная строка с приглашением «MariaDB». Далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php. Теперь нужно пользователю предоставить привилегии для работы с этой базой данных.



```
(zvpanina@kali)~/var/www/html/DVWA/config
$ sudo su
(zvpanina@kali)~/var/www/html/DVWA/config
$ mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-1+1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]>
MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.001 sec)

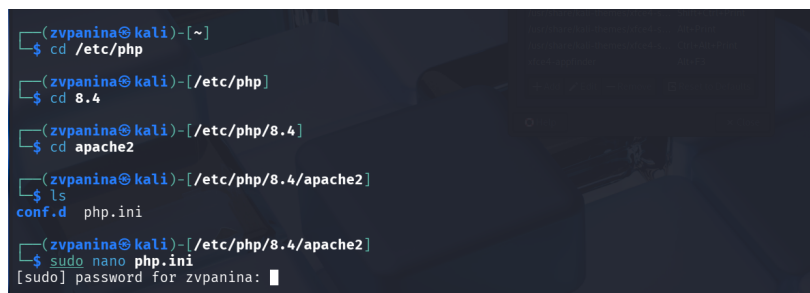
MariaDB [(none)]> create user 'userDVWA'@'127.0.0.1' identified by 'dvwa';
Query OK, 0 rows affected (0.010 sec)

MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' identified by 'dvwa';
Query OK, 0 rows affected (0.004 sec)

MariaDB [(none)]> exit
Bye
(zvpanina@kali)~/var/www/html/DVWA/config
```

Рисунок 4.5: Авторизация в базе данных и предоставление привилегий

Необходимо настроить сервер apache2, перехожу в соответствующую директорию (?@fig-006). В файле `php.ini` нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе.



```
(zvpanina@kali)~
$ cd /etc/php
(zvpanina@kali)~/etc/php
$ cd 8.4
(zvpanina@kali)~/etc/php/8.4
$ cd apache2
(zvpanina@kali)~/etc/php/8.4/apache2
$ ls
conf.d  php.ini
(zvpanina@kali)~/etc/php/8.4/apache2
$ sudo nano php.ini
[sudo] password for zvpanina:
```

Рисунок 4.6: Перемещение между директориями

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как On (?@fig-007).

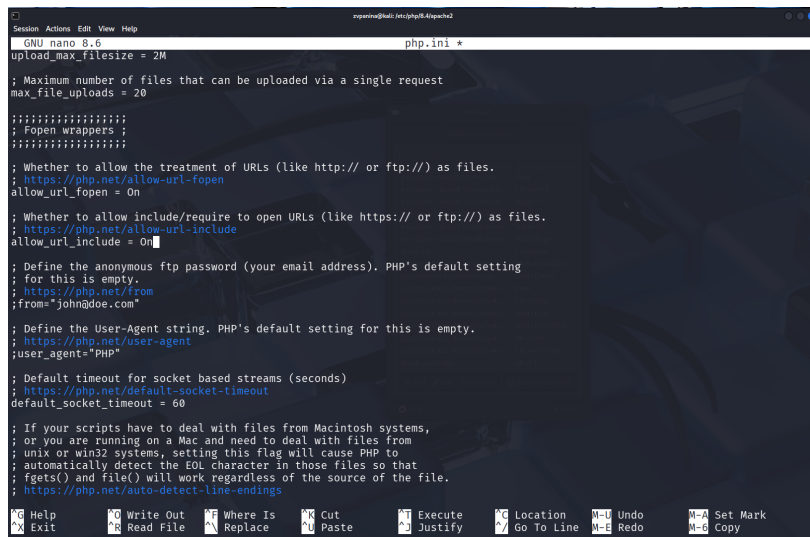


Рисунок 4.7: Редактирование файла

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (?@fig-008).

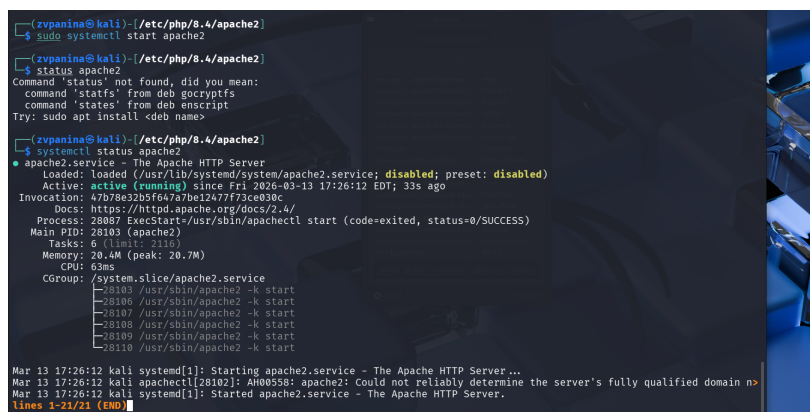


Рисунок 4.8: Запуск службы

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (?@fig-009).

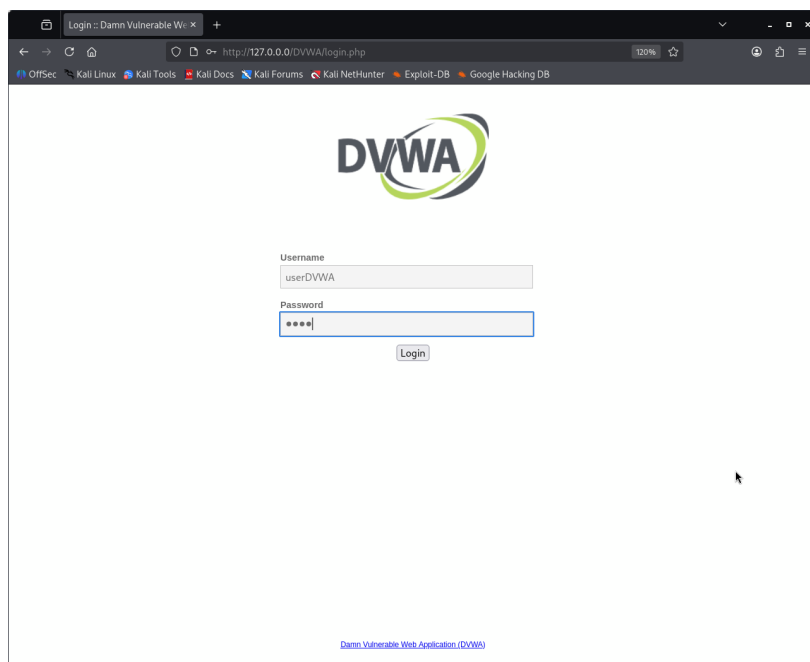


Рисунок 4.9: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку `create\reset database (?@fig-010)`.

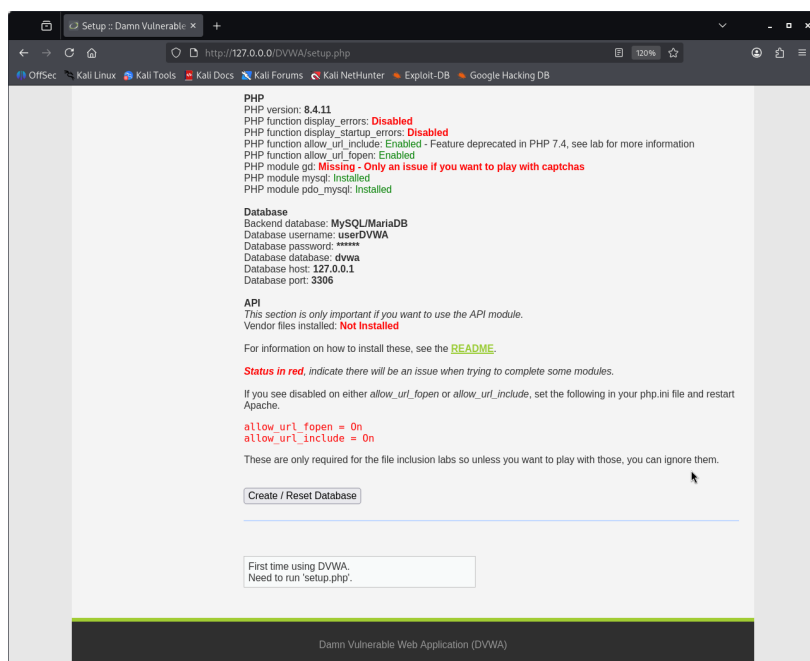


Рисунок 4.10: «Создание базы данных»

Авторизуюсь с помощью предложенных по умолчанию данных (?@fig-011).

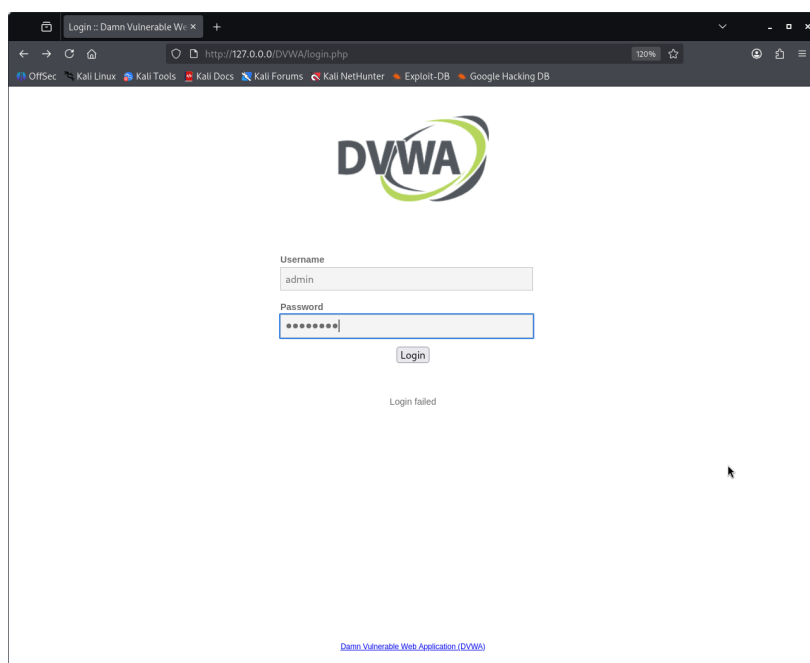


Рисунок 4.11: Авторизация

Оказываюсь на домашней странице веб-приложения, на этом установка окончена (?@fig-012).

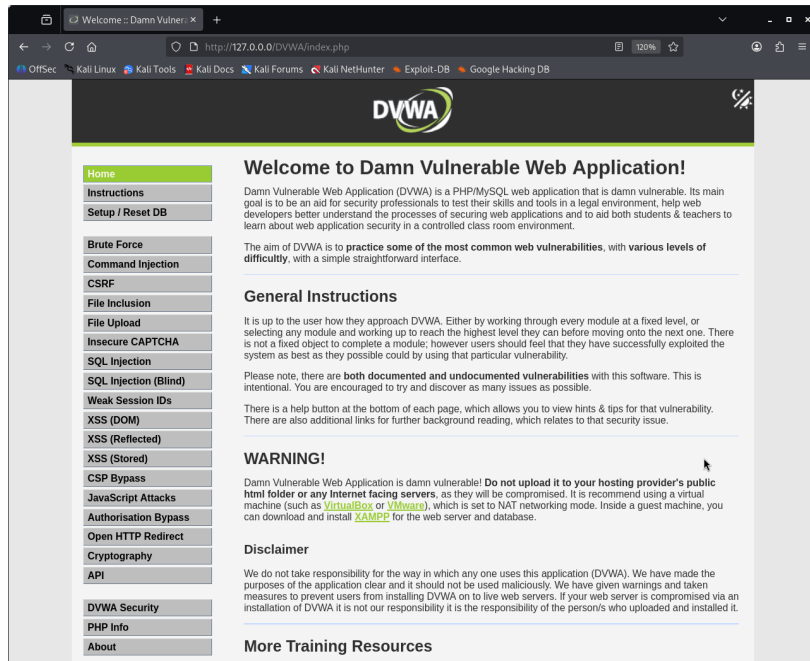


Рисунок 4.12: Домашняя страница DVWA

5 Выводы

В ходе работы я приобрела практические навыки по установке уязвимого веб-приложения DVWA.

Список литературы